GITLAB INC.

Politique de sécurité des systèmes d'information (PSSI)

GitLab - Livrable 3

Dérivée de l'analyse de risque EBIOS RM - politique proposée pour relecture

Contrôle du document

Rubrique	Détail
Référence du document	GRC-GL-2026-03
Version / statut	1.0 - Projet pour relecture
Date	5 octobre 2026
Date limite des preuves	4 octobre 2026 (sources publiques uniquement)
Classification	Confidentiel - livrable d'analyste
Type d'étude	Évaluation externe, sur sources publiques, du risque cyber et de la gouvernance de la sécurité
Méthodologie	EBIOS Risk Manager (ANSSI) - PSSI - traitement du risque - analyse d'écarts - feuille de route
Objet	GitLab.com, GitLab Dedicated, produit auto-hébergé, Duo / Duo Agent Platform

Déclaration de périmètre

Ce document n'est ni un audit interne, ni un test d'intrusion, ni une évaluation de vulnérabilités, ni un audit de certification ISO/IEC 27001, et il n'affirme pas que GitLab n'est pas sûr. La mention « non vérifiable publiquement » ne signifie jamais « absent ». Tous les scores de risque sont des jugements d'analyste fondés sur des sources publiques et doivent être validés avec les données internes de GitLab.

Nature de ce document
Cette PSSI est une politique proposée, dérivée d'une analyse de risque externe sur sources publiques. Elle vise à modéliser les exigences qui devraient encadrer les principaux risques de GitLab ; les politiques internes de GitLab prévalent. Les responsables sont des rôles proposés.

Sommaire

Si cette page apparaît vide, ouvrez le fichier dans Microsoft Word et choisissez « Mettre à jour le champ » pour générer la table des matières.

1. Objet, périmètre et statut

Cette politique définit les principes de sécurité, exigences, responsabilités et processus de revue qui devraient encadrer la confidentialité, l'intégrité, la disponibilité et l'authenticité des environnements SaaS, Dedicated et de livraison produit de GitLab, y compris les capacités d'IA.

Périmètre : GitLab.com SaaS multi-tenant (plateforme de production, runners CI partagés, registres, fonctions d'IA). ; GitLab Dedicated, y compris le plan de contrôle Switchboard et les comptes AWS des tenants exploités par GitLab. ; Ingénierie produit et chaîne de livraison produisant le logiciel auto-hébergé et le code SaaS. ; Capacités d'IA (GitLab Duo / Duo Agent Platform) et dépendances envers les fournisseurs de modèles. ; Gouvernance de la sécurité, identité des collaborateurs et administration pouvant atteindre les éléments ci-dessus. ; Tiers et sous-traitants que GitLab déclare publiquement comme participant à la fourniture du service.

Statut : v1.0 proposée, dérivée du registre de 13 risques. Cycle de revue : annuel, ou après un incident majeur ou un changement d'architecture.

2. Principes de sécurité

1. **Le contenu des clients est sacré** - le code, les secrets et les données des clients sont protégés comme les actifs de plus grande valeur.
2. **Supposer la compromission des identités** - l'accès privilégié est minimal, fort, temporaire et surveillé.
3. **Intégrité de ce que nous livrons** - tout ce qui est livré aux clients est construit, revu et signé de façon vérifiable.
4. **Sécurisé par défaut et par conception** - les composants à haut risque sont modélisés et testés avant release.
5. **L'IA est un acteur privilégié** - les agents respectent le moindre privilège, des jetons à périmètre limité et une approbation humaine pour les actions sensibles.
6. **Préparés, pas seulement protégés** - détection, réponse et reprise sont répétées et mesurées.
7. **Transparence responsable** - l'ouverture est une valeur, bornée par la classification et des garde-fous automatisés.
8. **Mesurer pour piloter** - chaque exigence a un responsable, un cycle de revue et des indicateurs.

3. Gouvernance et responsabilités

Rôle	Responsabilités
Comité d'audit du conseil d'administration	Supervise le risque cyber ; reçoit le pack d'indicateurs trimestriel ; accepte les risques résiduels Critiques/Élevés.
RSSI (intérim ou titulaire)	Porte cette PSSI et le registre des risques ; rend compte au comité d'audit ; arbitre les exceptions.
Gouvernance de la sécurité / Assurance	Maintient la politique, les indicateurs, le registre des exceptions et les preuves ; coordonne les audits.
Responsables de domaine	Responsables des exigences de leur domaine (voir catalogue) ; rapportent les indicateurs ; proposent les exceptions.
Dirigeants Ingénierie et Produit	Mettent en œuvre le développement sécurisé, l'intégrité des releases et les mesures sur runners et IA.
Tous les collaborateurs, prestataires et personnel PEO	Respectent la politique et signalent incidents et activités suspectes.

4. Catalogue des exigences

GOV - Gouvernance et gestion des risques

GOV-01 - Leadership et responsabilité de la sécurité

Champ	Contenu
Exigence	Un responsable sécurité exécutif nommé et redevable, avec droits de décision, suppléants et dispositions de succession documentés, doit exister en permanence ; toute vacance doit déclencher un plan de continuité documenté approuvé par le comité d'audit.
Risques traités	R-11, R-01, R-02
Responsable (proposé)	Comité d'audit / DG
Fréquence de revue	Trimestrielle
Indicateurs	- Jours sans RSSI titulaire (cible : 0 sans plan de continuité) - % de risques critiques avec un responsable exécutif nommé
Correspondance référentiels	ISO 27002 5.2, 5.4 ; NIST CSF GV.RR ; SOC 2 CC1.3

GOV-02 - Intégration de la gestion des risques

Champ	Contenu
Exigence	Les risques cyber doivent être évalués selon une méthode et des échelles définies, consignés dans un registre avec propriétaires, décisions de traitement et acceptation du risque résiduel, et intégrés à la gestion des risques d'entreprise au moins une fois par an.
Risques traités	R-11
Responsable (proposé)	RSSI / Audit interne
Fréquence de revue	Annuelle (registre : trimestrielle)
Indicateurs	- % de risques avec une décision de traitement à jour - % de risques résiduels formellement acceptés - Ancienneté de la dernière évaluation complète des risques
Correspondance référentiels	ISO 27002 5.1 ; NIST CSF GV.RM, ID.RA ; SOC 2 CC3.1-CC3.4

GOV-03 - Gestion des politiques et des exceptions

Champ	Contenu
Exigence	Les politiques de sécurité doivent être des documents contrôlés avec propriétaires, versionnement, cycles de revue obligatoires et un processus d'exception suivi et limité dans le temps.
Risques traités	R-11, R-12
Responsable (proposé)	Assurance sécurité
Fréquence de revue	Annuelle
Indicateurs	- % de politiques revues dans les délais - Nombre d'exceptions ouvertes au-delà de leur échéance
Correspondance référentiels	ISO 27002 5.1, 5.36 ; NIST CSF GV.PO ; SOC 2 CC1.4, CC5.3

GOV-04 - Indicateurs de sécurité et reporting au conseil

Champ	Contenu
Exigence	Un jeu d'indicateurs couvrant les principaux risques doit être rapporté chaque mois à la direction et au moins chaque trimestre au comité d'audit, avec tendance, cible et responsable d'action.

Champ	Contenu
Risques traités	R-11, R-02
Responsable (proposé)	Gouvernance de la sécurité
Fréquence de revue	Trimestrielle
Indicateurs	- Pack d'indicateurs trimestriel livré à l'heure - % d'indicateurs avec cible et responsable
Correspondance référentiels	ISO 27002 5.4 ; NIST CSF GV.OV ; SOC 2 CC2.2

IAM - Gestion des identités et des accès

IAM-01 - Accès privilégiés

Champ	Contenu
Exigence	Les accès privilégiés à la production, aux racines d'organisation cloud, au plan de contrôle Dedicated, à la signature et à l'administration CI/CD doivent être inventoriés, fortement authentifiés, accordés au moindre privilège et juste-à-temps, revus au moins chaque trimestre, surveillés et révoqués sous 24 heures dès que le besoin cesse.
Risques traités	R-01, R-07, R-08, R-03
Responsable (proposé)	Responsable Identités et Accès
Fréquence de revue	Trimestrielle
Indicateurs	- % de comptes privilégiés couverts par un MFA résistant à l'hameçonnage (cible 100 %) - % de comptes privilégiés revus le trimestre écoulé (cible 100 %) - Délai moyen de révocation d'un accès privilégié (cible < 24 h) - % d'accès de production en juste-à-temps
Correspondance référentiels	ISO 27002 5.15, 5.18, 8.2 ; NIST CSF PR.AA ; SOC 2 CC6.1-CC6.3

IAM-02 - Authentification des collaborateurs

Champ	Contenu
Exigence	Tous les accès des collaborateurs doivent utiliser le SSO avec un MFA résistant à l'hameçonnage (FIDO2/passkeys) pour les rôles privilégiés et ceux qui atteignent la production ; durée de session, posture de l'appareil et liaison des jetons doivent limiter le rejeu de sessions volées.
Risques traités	R-01, R-08
Responsable (proposé)	Responsable Identités et Accès / IT
Fréquence de revue	Semestrielle
Indicateurs	- % de comptes de collaborateurs sous SSO+MFA - % de connexions privilégiées avec facteurs résistants à l'hameçonnage - Durée médiane de session Tier-0
Correspondance référentiels	ISO 27002 8.5, 5.17 ; NIST CSF PR.AA ; SOC 2 CC6.1

IAM-03 - Cycle de vie des accès, y compris prestataires et personnel PEO

Champ	Contenu
Exigence	Les processus arrivée/mobilité/départ doivent couvrir uniformément salariés, prestataires et personnel PEO/externalisé, avec retrait automatisé des droits et recertification périodique par les propriétaires de systèmes.
Risques traités	R-08, R-01
Responsable (proposé)	Responsable Identités et Accès / RH

Champ	Contenu
Fréquence de revue	Trimestrielle
Indicateurs	- % de départs désactivés sous 24 h - % de comptes prestataires/PEO recertifiés - Nombre de comptes orphelins
Correspondance référentiels	ISO 27002 5.16, 5.18, 6.5 ; NIST CSF PR.AA ; SOC 2 CC6.2, CC6.3

IAM-04 - Identités machines, jetons et secrets

Champ	Contenu
Exigence	Les identités non humaines (comptes de service, jetons de job CI, clés API/de déploiement, jetons MCP/agents) doivent être inventoriées, attribuées à un propriétaire, restreintes, expirantes et renouvelées ; les secrets ne doivent pas figurer dans le code source ou le contenu public, ce que des scans automatisés garantissent.
Risques traités	R-01, R-13, R-06
Responsable (proposé)	Sécurité des plateformes
Fréquence de revue	Trimestrielle
Indicateurs	- % d'identités machines avec propriétaire et expiration - Âge moyen des secrets - Secrets détectés dans les dépôts internes/publics par trimestre
Correspondance référentiels	ISO 27002 5.17, 8.4, 8.24 ; NIST CSF PR.AA, PR.DS ; SOC 2 CC6.1

SSC - Développement sécurisé et chaîne d'approvisionnement logicielle

SSC-01 - Intégrité du build et des releases

Champ	Contenu
Exigence	Les artefacts de release doivent être construits sur une infrastructure éphémère et hermétique, avec provenance vérifiable, signature cryptographique à clés protégées et approbation à deux personnes des changements impactant la release.
Risques traités	R-03
Responsable (proposé)	VP Ingénierie / Ingénierie de release
Fréquence de revue	Trimestrielle
Indicateurs	- % d'artefacts de release avec provenance vérifiable (cible 100 %) - % de changements impactant la release approuvés à deux personnes - Revues d'accès aux clés de signature réalisées
Correspondance référentiels	ISO 27002 8.25, 8.31, 8.32 ; NIST CSF PR.PS, GV.SC ; SOC 2 CC8.1

SSC-02 - Gouvernance des contributeurs et des dépendances

Champ	Contenu
Exigence	Les contributions externes et dépendances tierces doivent être gouvernées par le durcissement des comptes de mainteneurs, des portes de revue obligatoires, l'épinglage des dépendances, la génération de SBOM et le filtrage de paquets malveillants.
Risques traités	R-03
Responsable (proposé)	VP Ingénierie / Sécurité produit
Fréquence de revue	Trimestrielle
Indicateurs	- % de mainteneurs avec MFA résistant à l'hameçonnage - % de dépendances épinglées et couvertes par SBOM - Délai moyen de correction d'une dépendance vulnérable

Champ	Contenu
Correspondance référentiels	ISO 27002 5.19-5.21, 8.28, 8.30 ; NIST CSF GV.SC, ID.RA ; SOC 2 CC9.2

SSC-03 - Gestion des vulnérabilités, divulgation et publication de correctifs

Champ	Contenu
Exigence	Les vulnérabilités doivent être triées selon la gravité et l'exploitabilité (y compris le statut KEV), corrigées selon des SLA définis, divulguées par des processus coordonnés et communiquées aux clients avec des consignes de mise à niveau claires.
Risques traités	R-02, R-10
Responsable (proposé)	VP Sécurité produit
Fréquence de revue	Mensuelle
Indicateurs	- Délai médian de correction des Critiques (jours) - Délai entre correctif et avis client - % de SaaS corrigé avant divulgation publique
Correspondance référentiels	ISO 27002 8.8, 5.24 ; NIST CSF ID.RA, RS.MA ; SOC 2 CC7.1

SSC-04 - Développement sécurisé des composants à haut risque

Champ	Contenu
Exigence	Les composants qui traitent des entrées non fiables, appliquent l'autorisation ou exécutent la logique des clients (API, GraphQL, interpréteurs CI/CD, intégration d'IA) doivent avoir des modèles de menaces, des tests de cas d'abus, des portes de fuzzing/SAST et une revue indépendante.
Risques traités	R-02, R-06, R-09
Responsable (proposé)	VP Ingénierie / Sécurité produit
Fréquence de revue	Trimestrielle
Indicateurs	- % de composants à haut risque avec modèle de menaces à jour - Vulnérabilités Critiques/Élevées trouvées en interne vs signalées en externe - Taux d'échappement vers la production
Correspondance référentiels	ISO 27002 8.25-8.29 ; NIST CSF PR.PS ; SOC 2 CC8.1

SSC-05 - Accompagnement des mises à niveau et versions supportées

Champ	Contenu
Exigence	GitLab doit définir des fenêtres de versions supportées, fournir des consignes claires de mise à niveau d'urgence, et utiliser la télémétrie ou les notifications pour réduire les instances auto-hébergées non supportées et non corrigées.
Risques traités	R-10
Responsable (proposé)	VP Sécurité produit / Support
Fréquence de revue	Trimestrielle
Indicateurs	- % d'instances auto-hébergées sur des versions supportées - Délai médian en jours entre correctif et adoption par le client - Rétroportages vers des branches en fin de vie (nombre)
Correspondance référentiels	ISO 27002 8.8 ; NIST CSF RS.CO, GV.SC ; SOC 2 CC7.1

CLD - Cloud, plateforme et isolation des tenants

CLD-01 - Socle de sécurité cloud

Champ	Contenu
Exigence	Les comptes et projets cloud doivent suivre des socles durcis (identité, réseau, journalisation, chiffrement, garde-fous en code) avec surveillance continue de la posture et correction des dérives.
Risques traités	R-04, R-01
Responsable (proposé)	Sécurité cloud
Fréquence de revue	Semestrielle
Indicateurs	- % de comptes cloud conformes au socle - Délai moyen de correction d'une mauvaise configuration critique
Correspondance référentiels	ISO 27002 5.23, 8.9, 8.20 ; NIST CSF PR.PS, PR.IR ; SOC 2 CC6.6, CC7.1

CLD-02 - Isolation des tenants et plan de contrôle Dedicated

Champ	Contenu
Exigence	Les environnements de tenants doivent être isolés par conception, et le plan de contrôle durci avec des chemins d'administration séparés, des rôles inter-comptes au moindre privilège, un accès opérateur JIT et des tests indépendants des chemins inter-tenants.
Risques traités	R-07
Responsable (proposé)	Directeur Ingénierie Dedicated
Fréquence de revue	Semestrielle
Indicateurs	- Test indépendant des chemins inter-tenants réalisé (annuel) - % d'actions opérateur approuvées JIT et journalisées - Nombre de rôles inter-comptes permanents
Correspondance référentiels	ISO 27002 8.22, 8.31, 5.23 ; NIST CSF PR.IR ; SOC 2 CC6.1, CC6.6

CLD-03 - Isolation des runners et de l'exécution CI/CD

Champ	Contenu
Exigence	Les runners partagés doivent exécuter les jobs dans des environnements isolés à usage unique, sans privilèges par défaut, avec contrôles de sortie, protection du service de métadonnées et détection automatisée d'abus.
Risques traités	R-09
Responsable (proposé)	Directeur Plateforme Runners
Fréquence de revue	Semestrielle
Indicateurs	- % de jobs sur runners partagés en isolation à usage unique - Incidents d'abus détectés/bloqués par trimestre - Délai moyen de suspension d'un compte abusif
Correspondance référentiels	ISO 27002 8.22, 8.31 ; NIST CSF PR.IR, DE.CM ; SOC 2 CC6.6

CLD-04 - Protection des données, résidence et chiffrement

Champ	Contenu
Exigence	Le contenu des clients doit être classifié, chiffré en transit et au repos avec des clés gérées, les engagements de résidence respectés, et l'accès à la gestion des clés traité comme privilégié.
Risques traités	R-01, R-04

Champ	Contenu
Responsable (proposé)	DPO / Sécurité cloud
Fréquence de revue	Annuelle
Indicateurs	- % de stockages de données avec chiffrement et rotation de clés approuvés - Revues d'accès des administrateurs de clés réalisées - Exceptions de résidence
Correspondance référentiels	ISO 27002 8.24, 5.12, 5.34 ; NIST CSF PR.DS ; SOC 2 C1.1, CC6.7

AI - Sécurité de l'IA et des agents

AI-01 - Gouvernance de l'IA et modélisation des menaces

Champ	Contenu
Exigence	Les fonctions d'IA et agents doivent fonctionner sous un système de management de l'IA avec évaluation des risques documentée, modèles de menaces pour l'injection de prompt, la fuite de données et le détournement d'outils, et portes de release.
Risques traités	R-06
Responsable (proposé)	Responsable Sécurité de l'IA
Fréquence de revue	Trimestrielle
Indicateurs	- % de fonctions d'IA avec modèle de menaces à jour - Taux de réussite des tests d'injection de prompt - Incidents d'IA par trimestre
Correspondance référentiels	ISO 42001 ; ISO 27002 5.8 ; NIST CSF GV.RM, ID.RA ; SOC 2 CC3.2

AI-02 - Privilèges des agents, périmètre des jetons et traitement des sorties

Champ	Contenu
Exigence	Les agents et intégrations d'IA doivent fonctionner avec des jetons au moindre privilège, de courte durée et à périmètre appliqué ; les actions sensibles doivent exiger une approbation humaine ; la sortie des modèles doit être assainie et contrainte contre les canaux d'exfiltration.
Risques traités	R-06
Responsable (proposé)	Responsable Sécurité de l'IA
Fréquence de revue	Trimestrielle
Indicateurs	- % de jetons d'agent avec périmètre minimal appliqué - % d'actions sensibles d'agent exigeant une approbation - Vulnérabilités liées à l'IA ouvertes par gravité
Correspondance référentiels	ISO 27002 8.2, 8.28 ; NIST CSF PR.AA, PR.PS ; SOC 2 CC6.1

AI-03 - Dépendance aux fournisseurs d'IA et de modèles

Champ	Contenu
Exigence	Les dépendances aux fournisseurs de modèles d'IA doivent être inventoriées avec conditions de traitement des données, droits de notification de changement, modèles de secours et options de sortie.
Risques traités	R-04, R-06
Responsable (proposé)	Responsable Risques tiers / Plateforme IA
Fréquence de revue	Semestrielle

Champ	Contenu
Indicateurs	- % de fournisseurs d'IA avec évaluation à jour - Temps de bascule vers un modèle alternatif (testé)
Correspondance référentiels	ISO 27002 5.19-5.22 ; NIST CSF GV.SC ; SOC 2 CC9.2

RES - Résilience et réponse aux incidents

RES-01 - Continuité d'activité et reprise après sinistre

Champ	Contenu
Exigence	Les objectifs de reprise (RTO/RPO) de chaque service critique doivent être définis, testés de bout en bout, y compris pour la perte régionale, au moins une fois par an, et rapportés à la direction.
Risques traités	R-05
Responsable (proposé)	VP Infrastructure
Fréquence de revue	Trimestrielle
Indicateurs	- % de services critiques avec RTO/RPO testés - Dernier test de reprise régionale de bout en bout (jours) - RTO/RPO mesurés vs cibles
Correspondance référentiels	ISO 27002 5.29, 5.30 ; NIST CSF RC.RP ; SOC 2 A1.2, A1.3

RES-02 - Intégrité des sauvegardes et assurance de restauration

Champ	Contenu
Exigence	Les sauvegardes doivent être immuables, stockées dans des domaines de sécurité distincts avec une identité de reprise distincte, et testées en restauration selon un calendrier défini.
Risques traités	R-05
Responsable (proposé)	VP Infrastructure / Stockage
Fréquence de revue	Trimestrielle
Indicateurs	- % de jeux de données critiques avec copie immuable - Taux de réussite des tests de restauration - Nombre d'identités pouvant supprimer des sauvegardes (cible : minimal)
Correspondance référentiels	ISO 27002 8.13 ; NIST CSF PR.DS, RC.RP ; SOC 2 A1.2

RES-03 - Réponse aux incidents et communication client

Champ	Contenu
Exigence	Une capacité de réponse aux incidents testée doit classifier, contenir, investiguer et communiquer les incidents, y compris les notifications réglementaires et contractuelles et les avis publics pour les vulnérabilités de classe KEV.
Risques traités	R-02, R-05, R-10
Responsable (proposé)	Opérations de sécurité / Juridique / Communication
Fréquence de revue	Semestrielle
Indicateurs	- Délai moyen de détection / confinement / notification - Exercices réalisés par an - % de notifications dans les délais contractuels
Correspondance référentiels	ISO 27002 5.24-5.28 ; NIST CSF RS.MA, RS.CO ; SOC 2 CC7.3-CC7.5

MON - Détection et renseignement sur la menace

MON-01 - Journalisation, surveillance et couverture de détection

Champ	Contenu
Exigence	Les événements pertinents pour la sécurité issus de l'identité, du cloud, de la production, de la CI/CD et des services d'IA doivent être journalisés centralement, conservés et surveillés avec des détections alignées sur les chemins d'attaque prioritaires de l'organisation.
Risques traités	R-01, R-02, R-03
Responsable (proposé)	Opérations de sécurité
Fréquence de revue	Trimestrielle
Indicateurs	- % de systèmes critiques alimentant le SIEM - % de chemins d'attaque prioritaires avec détections testées - Délai moyen de détection lors d'exercices purple team
Correspondance référentiels	ISO 27002 8.15, 8.16 ; NIST CSF DE.CM, DE.AE ; SOC 2 CC7.2

MON-02 - Renseignement sur la menace et chasse proactive

Champ	Contenu
Exigence	Le renseignement sur la menace doit être collecté et opérationnalisé, y compris la surveillance du KEV, des échanges autour des exploits et de l'exposition aux infostealers de l'organisation, et servir à piloter des chasses et des changements d'urgence.
Risques traités	R-01, R-02
Responsable (proposé)	Gestion de la menace et des vulnérabilités
Fréquence de revue	Mensuelle
Indicateurs	- Délai entre signal KEV/exploit et action - Chasses réalisées par trimestre - Identifiants de collaborateurs trouvés dans des flux d'infostealers / délai de réinitialisation
Correspondance référentiels	ISO 27002 5.7 ; NIST CSF ID.RA, DE.AE ; SOC 2 CC7.2

TPM - Risque lié aux tiers et à la concentration

TPM-01 - Assurance des tiers et sous-traitants

Champ	Contenu
Exigence	Les tiers ayant accès aux données clients, identifiants ou à la production doivent être classés par niveau de risque, évalués avant intégration puis périodiquement, liés contractuellement à des clauses de sécurité et de notification de violation, et surveillés.
Risques traités	R-04, R-08
Responsable (proposé)	Responsable Risques tiers
Fréquence de revue	Semestrielle
Indicateurs	- % de tiers critiques évalués sur les 12 derniers mois - Constats critiques ouverts en retard - Clause de délai de notification de violation incluse (%)
Correspondance référentiels	ISO 27002 5.19-5.22 ; NIST CSF GV.SC ; SOC 2 CC9.2

TPM-02 - Concentration sur le cloud et les fournisseurs critiques

Champ	Contenu
Exigence	Le risque de concentration sur les hyperscalers, l'identité et les fournisseurs d'IA doit être évalué, avec un fonctionnement en mode dégradé et des plans de sortie/portabilité pour les services critiques.
Risques traités	R-04, R-05
Responsable (proposé)	Responsable Risques tiers / VP Infrastructure
Fréquence de revue	Annuelle
Indicateurs	- % de services critiques avec plan de sortie/mode dégradé documenté - Dernière revue de concentration (jours)
Correspondance référentiels	ISO 27002 5.23, 5.30 ; NIST CSF GV.SC, RC.RP ; SOC 2 A1.2

PPL - Personnes et risque interne

PPL-01 - Vérification des collaborateurs et sensibilisation à la sécurité

Champ	Contenu
Exigence	Tout le personnel, y compris prestataires et personnel PEO, doit être vérifié dans les limites légales et suivre une formation de sécurité par rôle incluant l'hameçonnage et l'ingénierie sociale assistée par IA.
Risques traités	R-08, R-01
Responsable (proposé)	RH / Sensibilisation à la sécurité
Fréquence de revue	Annuelle
Indicateurs	- % du personnel avec formation à jour - Taux d'échec aux simulations d'hameçonnage - % de rôles privilégiés avec vérification renforcée
Correspondance référentiels	ISO 27002 6.1, 6.3 ; NIST CSF PR.AT ; SOC 2 CC1.4

PPL-02 - Gestion du risque interne

Champ	Contenu
Exigence	Les rôles privilégiés et de support doivent faire l'objet d'une surveillance comportementale, d'une séparation des tâches et d'une escalade claire, en équilibre avec les exigences légales et de protection de la vie privée.
Risques traités	R-08
Responsable (proposé)	Assurance sécurité / Juridique / RH
Fréquence de revue	Semestrielle
Indicateurs	- Alertes d'activité privilégiée triées dans le SLA - Exceptions à la séparation des tâches
Correspondance référentiels	ISO 27002 5.3, 8.16 ; NIST CSF DE.CM, PR.AA ; SOC 2 CC6.3

TRN - Transparence responsable

TRN-01 - Transparence responsable

Champ	Contenu
Exigence	Le contenu publié dans le handbook, les issues publiques et la feuille de route doit être soumis à des règles de classification, à la détection automatisée de secrets et de données sensibles, et à des procédures de retrait et de rotation rapides.

Champ	Contenu
Risques traités	R-13
Responsable (proposé)	Responsable Assurance sécurité
Fréquence de revue	Semestrielle
Indicateurs	- Incidents de données sensibles dans le contenu public par trimestre - Délai moyen de retrait et de rotation - % de dépôts publics avec détection de secrets
Correspondance référentiels	ISO 27002 5.12, 5.14, 8.12 ; NIST CSF PR.DS, GV.PO ; SOC 2 C1.1

CMP - Conformité et assurance client

CMP-01 - Portefeuille de certifications et transitions de normes

Champ	Contenu
Exigence	Le portefeuille de certifications doit être maintenu avec un propriétaire et un calendrier ; les transitions d'édition de normes (p. ex. ISO 27001:2022) doivent être achevées avant les échéances et les déclarations publiques rester cohérentes avec les certificats.
Risques traités	R-12
Responsable (proposé)	Directeur Conformité sécurité
Fréquence de revue	Annuelle
Indicateurs	- % de certifications renouvelées avant expiration - Déclarations publiques rapprochées du périmètre du certificat (O/N) - Constats d'audit ouverts en retard
Correspondance référentiels	ISO 27002 5.35, 5.36 ; NIST CSF GV.OC ; SOC 2 CC1.2, CC4.1

CMP-02 - Transparence de l'assurance client

Champ	Contenu
Exigence	Les clients doivent pouvoir obtenir des éléments d'assurance à jour (rapports, lettres de continuité, synthèses de tests d'intrusion, politiques, changements de sous-traitants) via un portail en libre-service avec une cadence de rafraîchissement définie.
Risques traités	R-12, R-10
Responsable (proposé)	Assurance sécurité
Fréquence de revue	Semestrielle
Indicateurs	- Délai médian de traitement d'une demande d'assurance - Fraîcheur des éléments (ancienneté du plus ancien) - Satisfaction client sur l'assurance
Correspondance référentiels	ISO 27002 5.36 ; NIST CSF GV.OC ; SOC 2 CC2.3

5. Exceptions

- Les exceptions exigent une justification écrite, une évaluation de risque, des mesures compensatoires, un approbateur nommé (responsable de domaine plus RSSI ; comité d'audit pour les risques Critiques) et une échéance d'au plus 12 mois.
- Toutes les exceptions sont consignées dans un registre central ; les exceptions échues sont escaladées automatiquement.
- Le nombre et l'ancienneté des exceptions sont rapportés dans le pack d'indicateurs trimestriel (GOV-04).

6. Suivi et conformité

Mécanisme	Fréquence	Responsable
Collecte des indicateurs et tableau de bord	Mensuelle	Gouvernance de la sécurité
Revue de direction	Mensuelle	RSSI
Rapport au comité d'audit	Trimestrielle	RSSI
Tests de contrôles internes / surveillance continue des mesures	Trimestrielle	Assurance sécurité
Assurance indépendante (SOC 2, ISO, FedRAMP)	Annuelle	Conformité sécurité
Mise à jour de l'évaluation des risques pilotée par la menace (EBIOS RM)	Annuelle ou après événement majeur	RSSI

7. Processus de revue

9. Les responsables de domaine confirment chaque année la pertinence des exigences et les cibles d'indicateurs.
10. Les changements suivent le processus de document contrôlé (approbation des propriétaires de code).
11. Les changements importants d'architecture, de paysage de menaces (p. ex. nouvelle classe KEV) ou de réglementation déclenchent une revue hors cycle.
12. L'historique des versions et les approbations sont conservés.

Annexe - Matrice exigences-risques

Exigence	Risques	Responsable	Fréquence
GOV-01 Leadership et responsabilité de la sécurité	R-11, R-01, R-02	Comité d'audit / DG	Trimestrielle
GOV-02 Intégration de la gestion des risques	R-11	RSSI / Audit interne	Annuelle (registre : trimestrielle)
GOV-03 Gestion des politiques et des exceptions	R-11, R-12	Assurance sécurité	Annuelle
GOV-04 Indicateurs de sécurité et reporting au conseil	R-11, R-02	Gouvernance de la sécurité	Trimestrielle
IAM-01 Accès privilégiés	R-01, R-07, R-08, R-03	Responsable Identités et Accès	Trimestrielle
IAM-02 Authentification des collaborateurs	R-01, R-08	Responsable Identités et Accès / IT	Semestrielle
IAM-03 Cycle de vie des accès, y compris prestataires et personnel PEO	R-08, R-01	Responsable Identités et Accès / RH	Trimestrielle
IAM-04 Identités machines, jetons et secrets	R-01, R-13, R-06	Sécurité des plateformes	Trimestrielle
SSC-01 Intégrité du build et des releases	R-03	VP Ingénierie / Ingénierie de release	Trimestrielle
SSC-02 Gouvernance des contributeurs et des dépendances	R-03	VP Ingénierie / Sécurité produit	Trimestrielle
SSC-03 Gestion des vulnérabilités, divulgation et publication de correctifs	R-02, R-10	VP Sécurité produit	Mensuelle
SSC-04 Développement sécurisé des composants à haut risque	R-02, R-06, R-09	VP Ingénierie / Sécurité produit	Trimestrielle
SSC-05 Accompagnement des mises à niveau et versions supportées	R-10	VP Sécurité produit / Support	Trimestrielle
CLD-01 Socle de sécurité cloud	R-04, R-01	Sécurité cloud	Semestrielle
CLD-02 Isolation des tenants et plan de contrôle Dedicated	R-07	Directeur Ingénierie Dedicated	Semestrielle
CLD-03 Isolation des runners et de l'exécution CI/CD	R-09	Directeur Plateforme Runners	Semestrielle
CLD-04 Protection des données, résidence et chiffrement	R-01, R-04	DPO / Sécurité cloud	Annuelle
AI-01 Gouvernance de l'IA et modélisation des menaces	R-06	Responsable Sécurité de l'IA	Trimestrielle
AI-02 Privilèges des agents, périmètre des jetons et traitement des sorties	R-06	Responsable Sécurité de l'IA	Trimestrielle
AI-03 Dépendance aux fournisseurs d'IA et de modèles	R-04, R-06	Responsable Risques tiers / Plateforme IA	Semestrielle
RES-01 Continuité d'activité et reprise après sinistre	R-05	VP Infrastructure	Trimestrielle
RES-02 Intégrité des sauvegardes et assurance de restauration	R-05	VP Infrastructure / Stockage	Trimestrielle
RES-03 Réponse aux incidents et communication client	R-02, R-05, R-10	Opérations de sécurité / Juridique / Communication	Semestrielle
MON-01 Journalisation, surveillance et couverture de détection	R-01, R-02, R-03	Opérations de sécurité	Trimestrielle
MON-02 Renseignement sur la menace et chasse proactive	R-01, R-02	Gestion de la menace et des vulnérabilités	Mensuelle
TPM-01 Assurance des tiers et sous-traitants	R-04, R-08	Responsable Risques tiers	Semestrielle
TPM-02 Concentration sur le cloud et les fournisseurs critiques	R-04, R-05	Responsable Risques tiers / VP Infrastructure	Annuelle
PPL-01 Vérification des collaborateurs et sensibilisation à la sécurité	R-08, R-01	RH / Sensibilisation à la sécurité	Annuelle
PPL-02 Gestion du risque interne	R-08	Assurance sécurité / Juridique / RH	Semestrielle

Exigence	Risques	Responsable	Fréquence
TRN-01 Transparence responsable	R-13	Responsable Assurance sécurité	Semestrielle
CMP-01 Portefeuille de certifications et transitions de normes	R-12	Directeur Conformité sécurité	Annuelle
CMP-02 Transparence de l'assurance client	R-12, R-10	Assurance sécurité	Semestrielle